FICHE 10 - SÉCURISER LES SITES WEB

S'assurer que les bonnes pratiques minimales sont appliquées aux sites web.

Tout site web doit garantir son identité aux terminaux s'y connectant et la confidentialité des informations transmises..

Les précautions élémentaires

- **Sécuriser les flux d'échange de données** par l'utilisation de TLS :
  - **obtenir des certificats** aux niveaux adaptés (domaine, organisation ou étendu) auprès d'une autorité de certification et les gérer de manière adéquate ;
  - mettre en œuvre le protocole **TLS** (en remplacement de SSL[43]) sur tous les sites web, en utilisant uniquement les versions les plus récentes et en vérifiant sa bonne mise en œuvre ;
  - **rendre l'utilisation de TLS obligatoire** pour toutes les pages d'authentification ou sur lesquelles sont affichées ou transmises des données personnelles.
- **Limiter les ports de communication** strictement nécessaires au bon fonctionnement des applications installées. Si l'accès à un serveur web passe uniquement par HTTPS, il faut autoriser uniquement les flux réseau IP entrants sur cette machine sur le port 443 et bloquer tous les autres ports.
- **Limiter l'accès aux outils et interfaces d'administration aux seules personnes habilitées**. En particulier, limiter l'utilisation des comptes administrateur aux équipes en charge de l'informatique interne et ce, uniquement pour les actions d'administration qui le nécessitent.
- Implémenter les options « *HttpOnly* » et « *Secure* » dans tous les cookies utilisés.
- **Si des cookies non nécessaires au service sont utilisés, recueillir le consentement** de l'internaute après information de celui-ci et avant le dépôt du cookie.
- **Limiter le nombre de composants mis en œuvre**, en effectuer une veille régulière et les mettre à jour.
- **Limiter les informations renvoyées lors de la création d'un compte utilisateur ou lors de la réinitialisation d'un mot de passe**, afin de ne pas renseigner un attaquant sur l'existence – ou non – d'un compte associé à un identifiant (ex. : adresse de messagerie électronique).
- **Adopter les bonnes pratiques pour le développement informatique** (voir la fiche n°11 - Encadrer les développements informatiques). En particulier, **se prémunir contre les attaques les plus courantes sur les sites web référencées dans le Top 10 OWASP**[44] (ex. : injections SQL[45], injections de code indirecte (« *cross-site scripting* » ou XSS)[46], manipulations d'URL[47]).

43 Le protocole TLS est parfois appelé, à tort, SSL ou SSL/TLS. Le protocole SSL, prédécesseur de TLS, est aujourd'hui obsolète et à proscrire.

44 L'OWASP (Open web application security project) publie régulièrement une liste des dix risques les plus critiques pour les applications web (voir « OWASP Top Ten », owasp.org).

45 « SQL Injection », owasp.org

46 « Cross Site Scripting (XSS) », owasp.org

47 « Path Traversal », owasp.org